

Amazon Cognito: User Pools

Autenticação e Gerenciamento de Usuários

AWS Certified Developer Associate

Instrutor: Marlon Anesi

O que é um User Pool?

User Pool = diretório gerenciado de usuários. Lida com signup, signin, MFA, recuperação de senha e emite tokens JWT (ID, Access, Refresh).

Funcionalidades principais:

Signup / Signin

Email, telefone, username. Auto-verificação de email/SMS.

MFA e Segurança

TOTP, SMS MFA. Password policies. Bloqueio por tentativas.

Federated Login

Google, Facebook, Apple, SAML, OIDC providers externos.

JWT Tokens

Emitte ID Token, Access Token e Refresh Token (OAuth 2.0).

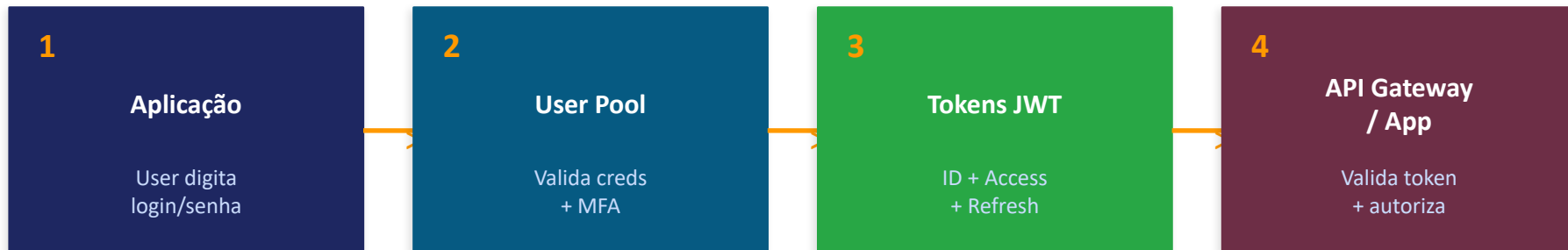
Lambda Triggers

Pre/post auth, custom messages, token generation.

Hosted UI

Interface de login gerenciada, configurável com domínio próprio.

Fluxo de Autenticação e Tokens JWT



Os 3 Tokens do Cognito User Pool:

ID Token (JWT)

- Contém claims do usuário (email, sub, grupos)
- Validade padrão: 1 hora
- Usado para identificar o usuário na app
- Contém atributos customizados

Access Token (JWT)

- Contém scopes OAuth 2.0
- Validade padrão: 1 hora
- Controla acesso a APIs protegidas
- NÃO contem atributos do usuário

Refresh Token

- Validade até 3650 dias (configurável)
- Usado para obter novos ID/Access tokens
- Não é JWT (opaco)
- Invalido após logout ou revogação

Lambda Triggers: Customizando o Fluxo

Pre Signup	<code>pre-signup</code>	Validações customizadas antes de criar o usuário. Pode rejeitar o registro.
Post Confirmation	<code>post-confirmation</code>	Executar ações após usuário confirmar conta (ex: criar registro em DynamoDB).
Pre Authentication	<code>pre-authentication</code>	Permitir ou bloquear tentativa de login antes de validar credenciais.
Post Authentication	<code>post-authentication</code>	Log de acesso, atualizações após login bem-sucedido.
Pre Token Generation	<code>pre-token-generation</code>	Adicionar ou remover claims nos tokens JWT antes de emitir.
Custom Message	<code>custom-message</code>	Customizar emails de verificação, SMS e notificações.
User Migration	<code>migrate-user</code>	Migrar usuário de sistema legado: se não existe no pool, busca em outro sistema.

Dica: Pre Token Generation permite adicionar roles/grupos aos claims -> controle de acesso granular na API

Casos de Uso e Boas Práticas

Aplicação Web / Mobile

- Signup/signin gerenciado pelo Cognito
- Hosted UI ou UI customizada com SDK
- Token JWT para chamar API Gateway
- MFA obrigatório para dados sensíveis

API Gateway + Cognito Authorizer

- Usar Cognito User Pool como Authorizer
- API Gateway valida ID Token automaticamente
- Sem código de autenticação no backend
- Grupos do User Pool mapeam para scopes

Boas Práticas:

- Habilite Advanced Security para detecção de uso de senha comprometida
- Use Grupos para controle de acesso (mapeados em claims do token)
- Configure Refresh Token com validade adequada ao risco da aplicação
- Versão atual dos limites: consultar a documentação AWS Cognito para valores atuais

Pontos-chave para o Exame

1

User Pool = autenticação (quem e voce)

Gerencia usuários, senha, MFA, tokens JWT. Não dá acesso direto a serviços AWS. Isso é função do Identity Pool.

2

3 tokens: ID, Access, Refresh

ID Token: claims do usuário. Access Token: scopes OAuth. Refresh Token: renovar os outros (validade maior).

3

Pre Token Generation = customização de claims

Trigger mais cobrado no exame. Permite adicionar roles/atributos ao JWT antes de emitir.

LEMBRE-SE: Cognito User Pool = quem voce e (autenticação). Identity Pool = o que voce pode fazer (autorização AWS)!